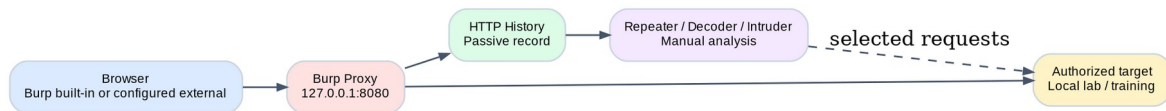


RED TEAM LEARNING PATH

MODULE 10

Burp Suite Fundamentals

Proxy, HTTP History, Repeater, Scope, TLS, Decoder & Controlled Automation



Burp sits between your browser and an authorized target; interesting traffic is promoted into analysis tools.

Authorized-lab only

Semua hands-on di modul ini ditujukan untuk localhost, container milik sendiri, Web Security Academy, atau target yang secara eksplisit mengizinkan pengujian. Jangan memasukkan host pihak lain ke scope Burp tanpa izin.

Omarchy / Arch Linux Edition | v1.0 | 04 Oct 2026

1. Tujuan Pembelajaran

Setelah menyelesaikan Module 10, lo diharapkan mampu menggunakan Burp Suite sebagai workstation manual web testing tanpa bergantung pada automation atau payload hafalan.

- [] Menjelaskan posisi Burp Proxy di antara browser dan aplikasi.
- [] Menggunakan Burp built-in browser, HTTP History, Intercept, Repeater, Decoder, dan konsep dasar Intruder.
- [] Menetapkan target scope sejak awal dan membatasi noise/out-of-scope traffic.
- [] Mengamati cookies/session tanpa menganggap cookie sebagai sekadar string.
- [] Menjelaskan bagaimana HTTPS interception bekerja dan risiko memasang Burp CA pada browser eksternal.
- [] Membandingkan response setelah mengubah satu variabel di Repeater.
- [] Mencatat evidence dan observasi secara reproducible.

Prerequisite

Selesaikan Module 00-09, terutama HTTP & Web Fundamentals (03), Scope/RoE (06), dan Vulnerability Assessment (09). Lo harus sudah nyaman membaca raw HTTP request/response.

Tools

Tool	Peran di modul
Burp Suite Community Edition	Intercepting proxy + manual web testing workflow
Burp built-in browser	Browser preconfigured untuk Burp Proxy
curl	Baseline HTTP client untuk cross-check
Python 3	Local loopback training service
Docker	Optional OWASP Juice Shop lab
sha256sum / observation-log.py	Evidence integrity dan notes

2. Mental Model: Burp Bukan "Scanner Ajaib"

Burp Proxy adalah perantara. Browser mengirim request ke listener Burp, Burp meneruskan request ke server, lalu response kembali melalui Burp. Nilai utamanya adalah visibility dan controlled modification.



Workflow manual yang akan kita pakai berulang kali sampai module web exploitation.

Red Team perspective

Tool bukan tujuan. Pertanyaan yang lebih penting: request mana yang menarik, parameter apa yang dikontrol user, state apa yang dibawa cookie/token, dan apa yang berubah ketika satu input dimodifikasi?

3. Install Burp Suite di Omarchy

Untuk module ini gunakan Burp Suite Community Edition dari installer resmi PortSwigger. Kita sengaja tidak menjadikan random package/AUR sebagai jalur default untuk security tooling yang memproses traffic sensitif.

1. Buka halaman resmi PortSwigger: Burp Suite Community Edition -> Download and install.
2. Pilih installer Linux sesuai arsitektur device.
3. Simpan installer di direktori download dan catat hash lokal untuk provenance/evidence.
4. Jalankan installer sebagai user biasa. Gunakan sudo hanya jika installer memang meminta privilege untuk lokasi system-wide.
5. Pada first run, pilih temporary project / default configuration untuk latihan awal.

Contoh workflow setelah download resmi

```
cd ~/Downloads
sha256sum burpsuite_community_linux_*.sh
chmod +x burpsuite_community_linux_*.sh
./burpsuite_community_linux_*.sh
```

Hash note

Hash yang lo hitung sendiri berguna untuk membuktikan file yang sama dipakai kembali. Hash itu BUKAN verifikasi vendor kalau tidak dibandingkan dengan nilai resmi yang dipublikasikan vendor.

4. Built-in Browser vs External Browser

Burp built-in browser sudah dipreconfigure untuk Proxy dan cocok untuk belajar. Ini pilihan default kita karena mengurangi konfigurasi dan tidak perlu menambah trusted root CA ke browser harian.

Mode	Kelebihan	Risiko / trade-off
Built-in browser	Langsung bekerja; isolated workflow	Profile terpisah dari browser harian
External browser	Bisa menyerupai workflow browser utama	Perlu proxy config; HTTPS biasanya perlu trust Burp CA

Security note

Jangan pasang Burp CA ke trust store system-wide hanya demi latihan. Kalau perlu external browser, lebih aman pakai profile browser khusus testing. Trusted root CA punya kemampuan MITM terhadap koneksi yang browser percayai.

5. Proxy Listener

Secara default Burp membuat listener di loopback port 8080. Loopback penting: service proxy tidak perlu terekspos ke LAN hanya untuk local browser testing.

Cek listener lokal dari Omarchy

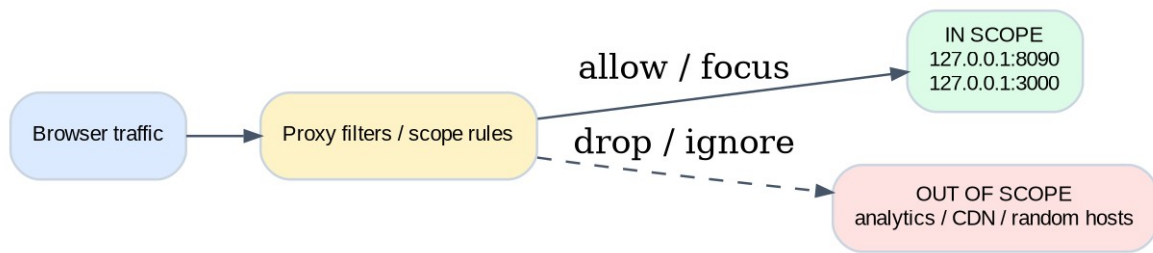
```
ss -ltnp | grep ':8080' || true
```

Common mistake

Jangan bind Burp listener ke 0.0.0.0 hanya karena "biar gampang". Itu memperluas attack surface workstation dan bisa membuat proxy dapat diakses device lain di jaringan.

6. Target Scope: Safety Boundary Pertama

Set scope sebelum mulai testing. Burp bisa memfilter Site map dan HTTP history berdasarkan scope, serta mengurangi kemungkinan tools mengirim request ke host yang tidak dimaksud.



Contoh scope Module 10: hanya service loopback yang kita miliki.

Scope item	Status	Alasan
http://127.0.0.1:8090/	IN	Custom Module 10 lab
http://127.0.0.1:3000/	IN	Optional Juice Shop container
analytics/CDN/random domains	OUT	Tidak dibutuhkan untuk latihan lokal

Guardrail helper untuk URL training

```
python labs/scope-guard.py http://127.0.0.1:8090/
python labs/scope-guard.py http://127.0.0.1:3000/
```

Important

"Ada di HTTP history" tidak sama dengan "boleh diuji". Browser modern menghubungi banyak third-party endpoint. Authorization tetap berasal dari scope/RoE, bukan dari Burp.

7. Proxy > HTTP History

HTTP History menyimpan traffic yang melewati Proxy bahkan saat Intercept dimatikan. Ini cocok untuk mode kerja normal: browse aplikasi tanpa gangguan, lalu pilih request menarik setelahnya.

- Filter ke in-scope traffic.
- Perhatikan method, URL, status code, MIME type, cookies, response length, dan TLS.
- Klik entry untuk membaca raw request dan response.
- Gunakan notes bila perlu agar request penting tidak hilang di antara noise.

Blue Team perspective

Proxy history juga mengingatkan bahwa setiap request meninggalkan pola: method, path, timing, cookies, dan sequence. Saat nanti belajar detection-aware operations, pikirkan telemetry yang dihasilkan oleh testing lo.

8. Intercept: Tahan, Ubah, Forward, Drop

Intercept cocok ketika lo ingin memodifikasi request sebelum server melihatnya. Tetapi browser menghasilkan banyak request, jadi Intercept sebaiknya dipakai secara sengaja, bukan selalu ON.

Action	Makna
Forward	Teruskan request yang sedang ditahan
Drop	Jangan kirim request ke server
Edit raw message	Ubah method/header/body sebelum forward
Send to Repeater	Salin request untuk eksperimen manual berulang

Common mistake

Kalau halaman terasa "hang", cek dulu apakah Intercept masih ON dan ada request yang sedang ditahan. Ini salah satu sumber kebingungan paling umum untuk pemula.

9. Repeater: Laboratory Bench untuk HTTP

Repeater memungkinkan satu request dikirim berulang dengan perubahan terkontrol. Ini adalah tool utama untuk membangun hipotesis secara manual.

Rule of one

Ubah SATU variabel per eksperimen ketika memungkinkan. Kalau lo mengganti method, cookie, parameter, dan header sekaligus, lo kehilangan kemampuan menjelaskan penyebab perubahan response.

Baseline	Change	Bandingkan
GET /echo?name=alice	name=bob	status, body, length
Cookie absent	Cookie present	state/response difference
POST JSON valid	JSON malformed	validation behavior
Redirect request	follow/no-follow	Location + final response

Contoh baseline request lokal

```
GET /echo?name=alice&role=user HTTP/1.1
Host: 127.0.0.1:8090
User-Agent: Burp-Training
Connection: close
```

10. Decoder dan Encoding

Burp Decoder membantu encode/decode URL encoding, HTML encoding, Base64, hex, dan transformasi lainnya. Encoding bukan encryption: tujuan utamanya representasi data, bukan secrecy.

Contoh representasi data

```
Original: role=user admin
URL encoded: role%3Duser%20admin
Base64: cm9sZT11c2VyIGFkbWlu
```

Security note

Jangan menganggap Base64, URL encoding, atau hex sebagai perlindungan secret. Kalau token sensitif hanya "disembunyikan" dengan encoding, siapa pun yang mendapatkannya bisa decode.

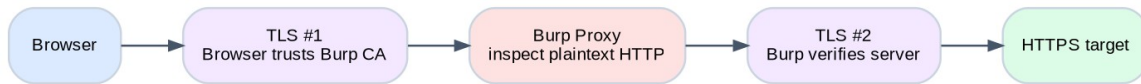
11. Cookies, Session, dan State

Burp sangat membantu melihat state yang dibawa browser. Perhatikan Set-Cookie pada response dan Cookie pada request berikutnya. Jangan edit token production atau akun real di luar scope.

Attribute	Pertanyaan pentest dasar
Secure	Apakah cookie hanya dikirim melalui HTTPS?
HttpOnly	Apakah JavaScript seharusnya dapat membacanya?
SameSite	Bagaimana cross-site delivery dibatasi?
Path / Domain	Ke request mana cookie berlaku?
Lifetime	Session cookie atau persistent cookie?

12. HTTPS Interception dan Burp CA

Untuk membaca HTTPS, Burp membuat dua koneksi TLS: browser <-> Burp dan Burp <-> server. Browser harus mempercayai CA milik Burp untuk menghindari warning ketika menggunakan external browser.



HTTPS interception memutus satu koneksi TLS menjadi dua koneksi TLS terpisah.

Prefer built-in browser

PortSwigger menyediakan browser bawaan yang sudah dikonfigurasi. Untuk module ini gunakan itu dulu. External browser + CA installation baru diperlukan kalau ada alasan yang jelas.

CA private key matters

Jika private key CA yang dipercaya browser bocor, pihak yang memegang key tersebut bisa membuat certificate yang dipercaya profile itu. Jaga workstation, gunakan profile testing terpisah, dan jangan menyalin CA/private key sembarangan.

13. Intruder Concepts - Controlled Automation

Intruder mengulang request dan memasukkan payload ke posisi tertentu. Fitur ini powerful, jadi Module 10 hanya menggunakan payload kecil terhadap loopback lab. Brute-force, credential attacks, dan aggressive fuzzing bukan objective modul ini.

Konsep	Makna
Payload position	Bagian request yang akan diganti
Payload set	Daftar nilai yang dicoba
Attack type	Cara payload dipetakan ke posisi
Resource / rate	Seberapa cepat request dikirim
Result columns	Status, length, timing, grep/extract fields

Safety budget

Untuk lab pertama cukup 3-5 payload pada endpoint localhost. Tujuannya memahami mekanisme dan membandingkan response, bukan menghasilkan traffic sebanyak mungkin.

14. Evidence Discipline

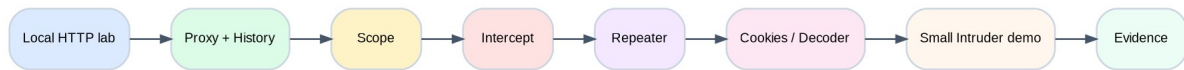
Burp membantu menemukan behavior, tapi report tetap membutuhkan evidence yang dapat direproduksi. Simpan request/response penting secara selektif dan catat apa yang berubah.

Field	Contoh
Request	GET /echo?name=alice
Tool	Proxy History -> Repeater
Change	name=alice -> name=bob
Observation	response JSON mengikuti parameter
Evidence	exported message / screenshot / hash
Conclusion	behavior confirmed; no vulnerability claim yet

Catat observasi, bukan asumsi

```
python labs/observation-log.py module10-burp/04-notes/observations.csv --tool Repeater --request 'GET /echo?name=bob' --observation 'Response JSON reflected name=bob'
```

15. Hands-on Lab Environment



Progression Module 10 dari local service ke evidence.

Local-first

Kita memakai service Python loopback untuk latihan core Burp. Juice Shop optional dan tetap dibind hanya ke 127.0.0.1 agar tidak terekspos ke LAN.

Lab 10.1 - Workspace dan Scope

```
./labs/workspace-init.sh module10-burp
cat module10-burp/00-scope/scope.txt
python labs/scope-guard.py http://127.0.0.1:8090/
```

- [] Workspace permission private (umask 077).
- [] Scope hanya loopback training URLs.
- [] Semua host lain dianggap OUT sampai ada authorization terpisah.

Lab 10.2 - Start Local HTTP Lab

```
python labs/burp-lab-server.py --port 8090
```

Di terminal lain:

```
curl -i http://127.0.0.1:8090/
curl -i 'http://127.0.0.1:8090/echo?name=alice&role=user'
```

Expected

Server bind hanya ke 127.0.0.1 dan menyediakan endpoint /echo, /cookie, /redirect, /login, /reflect untuk observasi protocol.

Lab 10.3 - Proxy + HTTP History

1. Buka Burp -> Proxy -> Intercept -> Open Browser.
2. Pastikan Intercept OFF agar browsing lancar.
3. Buka http://127.0.0.1:8090/.
4. Kunjungi /echo?name=alice&role=user, /cookie, dan /redirect.
5. Buka Proxy -> HTTP history dan filter traffic ke 127.0.0.1:8090.
6. Catat method, status, length, MIME type, cookies, dan redirect.

Lab 10.4 - Set Target Scope

1. Dari HTTP History atau Site map, add http://127.0.0.1:8090/ to scope.
2. Filter tampilan ke in-scope items.
3. Pastikan target lain tidak ikut diproses dalam workflow module.

Lab 10.5 - Intercept Satu Request

1. Aktifkan Intercept ON.
2. Di Burp browser buka /echo?name=alice&role=user.
3. Saat request tertahan, ubah name=alice menjadi name=bob.
4. Forward request.
5. Matikan Intercept kembali.
6. Bandingkan response dan catat perubahan.

Goal

Buktikan hubungan request -> modification -> response. Jangan mengejar "bug". Fokus ke kemampuan membaca dan mengontrol message.

Lab 10.6 - Repeater Baseline

1. Dari HTTP History pilih request /echo lalu Send to Repeater.
2. Kirim baseline tanpa perubahan.
3. Ubah hanya parameter name dan kirim lagi.
4. Ubah hanya role dan kirim lagi.
5. Bandingkan status, response body, dan length.

Catat observasi:

```
python labs/observation-log.py module10-burp/04-notes/observations.csv --tool Repeater --request 'GET /echo?name=bob&role=user' --observation 'Only name changed; JSON query value changed accordingly'
```

Lab 10.7 - Cookie Observation

1. Kunjungi /cookie.
2. Di response cari Set-Cookie.
3. Kunjungi /echo lagi dan lihat Cookie header yang browser kirim.
4. Identifikasi HttpOnly, SameSite, Path, dan apakah Secure ada.
5. Jangan menyimpulkan vulnerability hanya dari satu attribute tanpa context transport/application.

Lab 10.8 - Decoder

1. Pilih text `role=user admin` dan Send to Decoder.
2. URL-encode value tersebut.
3. Base64-encode value asli.
4. Decode kembali untuk membuktikan reversibility.
5. Catat perbedaan encoding vs encryption.

Lab 10.9 - Small Intruder Demo

Gunakan hanya endpoint loopback. Dari request `echo?name=alice`, kirim ke Intruder dan tandai hanya value `alice` sebagai payload position.

Payload set:

```
alice
bob
charlie
```

1. Jalankan attack kecil dengan tiga payload.
2. Bandingkan status dan response length.
3. Jangan tambahkan payload besar atau high-rate configuration.
4. Tutup attack setelah memahami mekanismenya.

Lab 10.10 - Optional Juice Shop Proxy Workflow

```
./labs/juice-shop-lab.sh create
./labs/juice-shop-lab.sh status
```

1. Add http://127.0.0.1:3000/ ke scope.
2. Browse halaman dengan Intercept OFF.

3. Gunakan HTTP History untuk mengenali XHR/fetch/API requests.
4. Pilih SATU harmless GET request dan kirim ke Repeater.
5. Jangan mengerjakan challenge exploitation dulu; objective hanya tool workflow.

Cleanup setelah selesai

```
./labs/juice-shop-lab.sh cleanup
```

16. Practical Challenge - "Map One Interaction"

Tanpa walkthrough, pilih satu interaction dari local Module 10 lab dan dokumentasikan alur lengkapnya.

- ☐ Scope URL ditulis jelas.
- ☐ Baseline request disimpan/catat.
- ☐ HTTP History entry diidentifikasi.
- ☐ Request dikirim ke Repeater.
- ☐ Hanya satu variabel diubah.
- ☐ Response dibandingkan secara eksplisit.
- ☐ Cookie/state dicatat bila relevan.
- ☐ Tidak ada claim vulnerability tanpa bukti impact.
- ☐ Evidence/notes memiliki timestamp dan hash bila ada file evidence.

Definition of done

Orang lain harus bisa membaca notes lo dan mengulangi eksperimen yang sama terhadap local lab untuk mendapatkan behavior yang setara.

17. Knowledge Check

1. Apa perbedaan HTTP History dengan Intercept?
2. Kenapa Intercept tidak perlu selalu ON?
3. Apa manfaat menetapkan Target Scope sebelum testing?
4. Kenapa traffic muncul di Burp tidak otomatis berarti authorized?
5. Kapan Repeater lebih berguna daripada browser biasa?
6. Kenapa mengubah satu variabel per eksperimen membantu reasoning?
7. Apa perbedaan encoding dengan encryption?
8. Bagaimana Set-Cookie berbeda dari Cookie?
9. Kenapa Burp built-in browser cocok untuk pemula?
10. Kenapa external browser HTTPS membutuhkan Burp CA?
11. Apa risiko dari trusted root CA?
12. Apa yang dimaksud payload position di Intruder?
13. Kenapa Intruder dibatasi ke payload kecil di module ini?
14. Bagaimana membuktikan evidence file tidak berubah?
15. Kapan lo boleh mulai menguji target non-local?

18. Exit Criteria

- ☐ Gue bisa menjalankan Burp Community Edition di Omarchy.
- ☐ Gue memahami listener loopback dan built-in browser.
- ☐ Gue bisa membuat scope dan memfilter history.
- ☐ Gue bisa intercept satu request dan mengembalikannya ke flow normal.
- ☐ Gue bisa menggunakan Repeater untuk baseline/change/compare.
- ☐ Gue bisa menggunakan Decoder untuk transformasi encoding dasar.
- ☐ Gue bisa menjelaskan cookie/session observation.
- ☐ Gue memahami konsep TLS interception dan Burp CA.

[] Gue memahami konsep Intruder tanpa melakukan brute-force.

[] Gue menyimpan notes/evidence yang reproducible.

19. Cheat Sheet

Tujuan	Lokasi / aksi
Buka browser Burp	Proxy -> Intercept -> Open Browser
Lihat semua traffic	Proxy -> HTTP history
Tetapkan scope	Target -> Scope / right-click request -> Add to scope
Tahan request	Proxy -> Intercept -> Intercept ON
Eksperimen manual	Send to Repeater
Transform encoding	Send to Decoder
Controlled automation	Send to Intruder
Default listener	127.0.0.1:8080
Local Module 10 target	127.0.0.1:8090
Optional Juice Shop	127.0.0.1:3000

20. Referensi Resmi

PortSwigger - Download and install Burp Suite - installer resmi Community / Professional

<https://portswigger.net/burp/documentation/desktop/getting-started/download-and-install>

PortSwigger - Burp Proxy - proxy architecture dan built-in browser

<https://portswigger.net/burp/documentation/desktop/tools/proxy>

PortSwigger - HTTP History - traffic history bahkan saat Intercept off

<https://portswigger.net/burp/documentation/desktop/tools/proxy/http-history>

PortSwigger - Target Scope - scope rules dan out-of-scope control

<https://portswigger.net/burp/documentation/desktop/tools/target/scope>

PortSwigger - Burp Repeater - manual request reissuing

<https://portswigger.net/burp/documentation/desktop/tools/repeater>

PortSwigger - Burp Decoder - encoding / decoding transforms

<https://portswigger.net/burp/documentation/desktop/tools/decoder>

PortSwigger - Burp Intruder - payload positions dan automated request variation

<https://portswigger.net/burp/documentation/desktop/tools/intruder>

PortSwigger - Installing Burp CA certificate - HTTPS interception dan trust considerations

<https://portswigger.net/burp/documentation/desktop/external-browser-config/certificate>

OWASP Developer Guide - Juice Shop - deliberately insecure training app + Docker

<https://devguide.owasp.org/en/07-training-education/01-vulnerable-apps/01-juice-shop/>

OWASP Juice Shop project - project overview dan training use

<https://owasp.org/projects/juice-shop>

Next module

Module 11 - Web Vulnerabilities I: SQL Injection, XSS, Command Injection, Path Traversal, File Upload, Authentication flaws, dan Access Control/IDOR - dengan PortSwigger labs dan local authorized targets.